١. مفهوم التحكم في الوصول (Access Control)

التحكم في الوصول هو أسلوب أمني يستخدم لتنظيم من يمكنه الوصول إلى الموارد داخل نظام الحاسوب وكيفية هذا الوصول.

يهدف إلى ضمان أن المستخدمين المصرح لهم فقط (Subjects) يمكنهم الوصول إلى الموارد (Objects) وفقا لصلاحيات محددة.

المكونات:

- Subjects المستخدمون العمليات
- Objects الموارد مثل الملفات وقواعد البيانات
- Access Rights الصلاحيات مثل القراءة والكتابة والتنفيذ

الأهداف:

- حماية السرية (Confidentiality)
- الحفاظ على السلامة (Integrity)
- ضمان التوافر (Availability)

الأهمية:

يساعد التحكم في الوصول في منع الوصول غير المصرح به، وتقليل المخاطر الأمنية وحماية البيانات الحساسة

٢. المقارنة بين DAC و MAC و RBAC

النموذج	الوصف	المميزات	العيوب
DAC	المالك يتحكم في الصلاحيات	مرن	أقل أمانا
MAC	جهة مركزية تتحكم	أمان عالي	جامد وغير مرن
RBAC	يعتمد على الأدوار	قابل للتوسع	تعقيد إدارة الأدوار

أمثلة:

- DAC مشاركة الملفات في Windows
- MAC الأنظمة العسكرية
- RBAC أنظمة الشركات

٣. مصفوفة التحكم في الوصول (Access Control Matrix)

هي جدول يوضح الصلاحيات التي يمتلكها كل مستخدم على كل مورد

طرق التطبيق:

- قوائم التحكم في الوصول: (ACIS) مرتبطة بالموارد
- قوائم القدرات: (Capability Lists) مرتبطة بالمستخدمين

المميزات:

- تمثيل واضح

٤. التحكم في الوصول المعتمد على الدور (RBAC)

الإجابة النموذجية:

يعتمد RBAC على منح الصلاحيات بناءً على الأدوار بدلاً من المستخدمين الأفراد.

خطوات العمل:

١. تعريف الأدوار (مثل مدير، موظف)

٢. تخصيص الصلاحيات لكل دور

٣. إسناد المستخدمين للأدوار

المميزات:

- تبسيط الإدارة
- تعزيز الأمان
- مناسب للأنظمة الكبيرة

٥. مشاكل نموذج DAC

الإجابة النموذجية:

- يمكن للمستخدمين نقل الصلاحيات للآخرين
- عرضة لهجمات Trojan Horse

٦. التحكم في الوصول في UNIX Linux

الإجابة النموذجية:

يعتمد UNIX على نظام الصلاحيات.

أنواع الصلاحيات:

- قراءة (R)
- كتابة (W)
- تنفيذ (X)

الفئات:

- المالك
- المجموعة
- الآخرون

ACLS:

تسمح بإعطاء صلاحيات إضافية المستخدمين محددين

٧. مبدأ أقل صلاحية (Least Privilege)

الإجابة النموذجية:

ينص هذا المبدأ على إعطاء المستخدم أقل قدر ممكن من الصلاحيات اللازمة لأداء عملهم.

الفوائد

٨. التحكم في الوصول في الأنظمة الحديثة

الإجابة النموذجية:

تشمل الأنظمة الحديثة:

- RBAC في المؤسسات
- المصادقة متعددة العوامل (MFA)
- التحكم في قواعد البيانات

مثال:

تستخدم أنظمة الحوسبة السحابية مثل AWS سياسات IAM.

يعزز الالتزام بالسياسات

لكن سوء تصميم الأدوار قد يقلل من كفاءته.

11. الفرق بين Authorizations و Authentication

الإجابة النموذجية:

العنصر	Authentication	Authorization
المعنى	التحقق من الهوية	تحديد الصلاحيات
مثال	تسجيل الدخول	الوصول للملفات

العلاقة:

يتم التحقق أولاً ثم تحديد الصلاحيات

١٢- التحكم المعتمد على الخصائص (ABAC)

الإجابة النموذجية

يعتمد ABAC على خصائص مثل:

- دور المستخدم
- الموقع
- الوقت

المقارنة:

- RBAC يعتمد على أدوار ثابتة ١
- ABAC يعتمد على قرارات ديناميكية

الميزة:

مرن ومناسب للأنظمة الحديثة

١. مفهوم توثيق المستخدم.

الإجابة:

توثيق المستخدم هو عملية التحقق من هوية المستخدم قبل منحه حق الوصول إلى النظام أبعد خطوة اسلامية في أمن المعلومات الضمان أن الشخص الذي يحاول الدخول هو بالفعل من يدعيه.

الأهداف:

- منع الوصول غير المصرح به
- حماية البيانات العامة
- دعم سياسات الأمان

الأهمية:

يساعد في تأمين الأنظمة وتقليل احتمالية الاختراقات والهجمات الاكترونية.

٢. عوامل التوثيق الثلاثة

الإجابة:

تعتمد انظمة التوثيق على ثلاثة عوامل رئيسية:

١. شيء تعرفه مثل كلمة المرور

٢. شيء تملكه مثل البطاقة الذكية أو الهاتف

٣. شيء تمثله مثل بصمة الإصبع أو الوجه

التقييم:

- العامل الأول سهل الاستخدام لكنه ضعيف الأمان
- العامل النشر أكثر أمانا لكنه قد يقد
- العامل الثالث قوي لكنه مكلف ويثير مخاوف الخصوصية

٣. التوثيق بكلمات المرور

الإجابة:

هو أكثر أنواع التوثيق استخدامًا.

نقاط الضعف:

- كلمات مرور ضعيفة
- إعادة استخدام كلمات المرور
- سهولة التخمين

الحلول:

- استخدام كلمات مرور قوية
- تغييرها بشكل دوري
- تطبيق سياسات امان صارمة

٤. التوثيق متعدد العوامل (MFA)

الإجابة:

يعتمد على استخدام أكثر من عامل توثيق.

الميزة:

حتى إذا تم اختراق عامل واحد، تبقى العوامل الأخرى تحمى النظام

مثال:

كلمة مرور + رمز يرسل إلى الهاتف

٥. التوثيق البيومتري

الإجابة:

يعتمد على الخصائص الحيوية للمستخدم

الميزات:

- صعب التزوير
- سهل الاستخدام

العيوب:

- تكلفة عالية
- مشاكل الخصوصية
- إمكانية الخطأ

٦. بروتوكولات التوثيق

الإجابة:

هي آليات للتحقق من الهوية عبر الشبكات.

مثال:

Challenge Response حيث يرسل النظام تحديا ويجب على المستخدم الرد بشكل صحيح.

٧. الهجمات على أنظمة التوثيق

الإجابة:

أنواع الهجمات:

- القوة الغاشمة
- هجمات القاموس
- التصيد الاحتيالي
- إعادة الإرسال

الحماية:

- استخدام MFA
- التشفير
- التوعية الأمنية

٨. تسجيل الدخول الموحد (SSO)

الإجابة:

يسمح للمستخدم بتسجيل الدخول مرة واحدة للوصول إلى عدة انظمة.

الميزات:

- سهولة الاستخدام
- تقليل عدد كلمات المرور

المخاطر:

- نقطة فشل واحدة
- إذا تم اختراق الحساب، تتأثر جميع الخدمات

٩. التوثيق في الأنظمة الحديثة

الإجابة:

يستخدم في:

- الحوسبة السحابية
- التطبيقات البنكية
- الخدمات الإلكترونية

مثال:

استخدام Google أو Microsoft تسجيل الدخول الموحد.

١٠. تخزين كلمات المرور

الإجابة:

يتم تخزينها باستخدام:

- Hashing تحويل الكلمة إلى قيمة غير قابلة للعكس
- Salting: إضافة قيمة عشوائية
- Key Stretching زيادة تعقيد الحساب:.

الهدف:

منع سرقة كلمات المرور.

١١. التوثيق بالرموز مقابل كلمات المرور

الإجابة:

العنصر	كلمات المرور	الرموز
الأمان	اقل	أعلى
الاستخدام	سهل	يحتاج جهاز
المخاطر	التخمين	القد

١٢. الاتجاهات الحديثة

الإجابة:

امثلة:

- التوثيق بدون كلمة مرور
- القياسات الحيوية السلوكية
- التوثيق التكيفي

الفائدة:

- تحسين الأمان
- تحسين تجربة المستخدم
- تقليل الاعتماد على كلمات المرور

١. مفهوم الأدوات التشفيرية ودورها في امن الحاسوب

الأدوات التشفيرية (Cryptographic Tools) هي مجموعة من الخوارزميات والتقنيات المستخدمة الحماية المعلومات أثناء التخزين أو النقل عبر الشبكات، بهدف منع الوصول غير المصرح به وضمان أمن البيانات.

دورها في الأمن:

- السرية (Confidentiality)

يتم ضمانها من خلال التشفير بحيث لا يمكن قراءة البيانات إلا من قبل الأطراف المصرح لها.

- السلامة (Integrity)

يتم التأكد من أن البيانات لم يتم تعديلها أثناء النقل باستخدام دوال التجزئة Hash Function

- التوثيق (Authentication)

التأكد من هوية المستخدم أو الطرف الآخر باستخدام التوقيعات الرقمية أو الشهادات.

- عدم الإنكار (Non-repudiation)

يمنع الطرف المرسل من إنكار إرسال البيانات باستخدام التوقيع الرقمي

٢. الفرق بين التشفير المتماثل وغير المتماثل

Symmetric key Cryptography

. يستخدم مفتاح واحد للتنفير وفك التشفير

أمثلة: AES DES.

المميزات:

- سريع في التنفيذ.
- مناسب للبيانات الكبيرة.

العيوب

- مشكلة توزيع المفتاح.
- أقل أماناً إذا تم تسريب المفتاح

Public-key Cryptography

- يستخدم مفتاحين عام وخاص
- امثلة RSA,ECC

المميزات:

- حل مشكلة توزيع المفاتيح.
- أمان أعلى في تبادل البيانات.

٣. عملية التشفير وفك التشفير

الشرح:

- التشفير تحويل النص الأصلي (Plaintert) إلى نص مشفر (Cphertext)
- فك التشفير إعادة النص المشفر إلى نصه الأصلي باستخدام مفتاح

مخطط (Block Diagram)

Plaintext + Key → encryption algorithm → Cphertext

Cphertext + Key → decryption algorithm → Plaintext

٤. دوال التجزئة(Hash Functions)

هي خوارزميات تحول البيانات إلى قيمة ثابتة الطول تسمى " Hash Value"

الخصائص:

- لا يمكن عكسها (One-way function).
- سرعة في الحساب.
- مقاومة التصادم (Collision Resistance)

الدور:

- ضمان سلامة البيانات.
- اكتشاف أي تعديل في الرسالة.
- تستخدم في التوقيعات الرقمية.

٥. التوقيعات الرقمية

هي تقنية تستخدم للتحقق من هوية المرسل وضمان عدم تغيير الرسالة.

آلية العمل:

- يتم إنشاء Hash للرسالة
- يتم تشفير الـ Hash باستخدام المفتاح الخاص.
- يتم إرسال الرسالة والتوقيع.

الأهمية:

- التوثيق (Authentication)
- عدم الإنكار (Non-repudiation)
- سلامة البيانات (Integrity) .

6. MACs ودورها ومقارنتها بالـ Hash

Message Authentication Code (MAC):

هو رمز ينشأ باستخدام مفتاح سري لضمان سلامة وأصالة الرسالة.

الدور: التحقق من أن الرسالة لم يتم تعديلها التأكد من مصدر الرسالة.

المقارنة مع: Hash

العنصر	Hash Function	MAC
المفتاح	لا يستخدم	يستخدم مفتاح سري
الأمان	اقل	أعلى
التوثيق	لايوفر	يوفر

٧. مشكلة إدارة المفاتيح (Key Management)

تشمل توليد، توزيع، تخزين، وتحديث المفاتيح التشفيرية.

التحدي:

- صعوبة توزيع المفاتيح بشكل امن
- خطر فقدان أو تسريب المفتاح.
- الحاجة إلى إدارة عدد كبير من المفاتيح في الأنظمة الكبيرة.

٨. توليد الأرقام العشوائية

الأهمية:

تستخدم في توليد المفاتيح التشفيرية والتوقيعات الرقمية.

خصائص المولد الجيد:

- العشوائية (Randomness)
- عدم التنبؤ.
- الاستقلالية.
- التوزيع المتساوي للقيم.

9. PKI ودورها في الاتصالات الآمنة

البنية التحتية للمفتاح العام (PKI) هي نظام لإدارة المفاتيح والشهادات الرقمية.

المكونات:

- الشهادات الرقمية.
- هيئة إصدار الشهادات (CA)
- هيئة التسجيل (RA)

الدور:

- تأمين تبادل المفاتيح.
- التحقق من الهوية الرقمية.
- دعم التوقيعات الرقمية.

١٠. الفرق بين الشهادات الرقمية والتوقيعات الرقمية

:Digital certificate

. وثيقة رقمية تربط الهوية بالمفتاح العام.

:Digital signature

. تقنية للتحقق من سلامة الرسالة وهوية المرسل.

الاستخدام معا:

- الشهادة تثبت هوية المستخدم.
- التوقيع يثبت أن الرسالة لم تتغير.

١١. الهجمات على الأنظمة التشفيرية

Brute force attack:

- تجربة جميع المفاتيح الممكنة.
- الوقاية: استخدام مفاتيح طويلة.

Cryptanalysis:

- تحليل الخوارزميات الاكتشاف المفتاح.
- الوقاية خوارزميات قوية مثل AES

Man-in-the-Middle:

- اعتراض الاتصال بين طرفين.
- الوقاية SSL/TLS : والشهادات الرقمية.

١٢. الاتجاهات الحديثة في التشفير

Quantum -resistant Cryptography

- خوارزميات مقاومة للحوسبة الكمية.
- مهمة لمواجهة أجهزة الكم المستقبلية.

Blockchain Cryptography

- تعتمد على التشفير التأمين المعاملات.
- تستخدم في العملات الرقمية.

Lightweight Cryptography

- خوارزميات خفيفة للأجهزة الصغيرة. (IoT)
- توفر أمان مع استهلاك منخفض للطاقة.